

Bayesian Network for Insider-Related Cyber Security Risk

Jan Ruijgrok
Open University of the Netherlands

July 2026

Abstract

Security teams assessing insider threats face incomplete HR, access, and monitoring signals; shareable incident data are scarce. This report develops and evaluates a compact Bayesian network for malicious insider-related cyber security risk. Experts specify people, process, and technology links; the model updates incident probability as evidence arrives. We validate inference on expert scenarios and test structure learning and classification on synthetically generated cases. Low- and high-risk profiles separate clearly; structure recovery improves with more data but edge direction remains harder than connectivity; on small test sets no classifier clearly dominates. The work is a proof of concept for analyst prioritisation, not validation on live operations data.

Keywords: insider threat; cyber security risk; Bayesian network; noisy-OR; structure learning; classification; ROC curve; People–Process–Technology.

Notation and symbols

Table 1: Main mathematical symbols.

Symbol	Meaning
I	InsiderThreatIncident (class)
E	Observed evidence
$P(I=\text{yes} \mid E)$	Target posterior incident probability
q, p_i	Noisy-OR leak and inhibitions on the incident node
n, N	Structure-learning subset size; synthetic pool ($N=2000$)
$AUC, F1$	Area under ROC curve; graph recovery score

Table 2: Network variables (eight nodes).

Variable	States	Description
JobDissatisfaction	low, medium, high	Employee dissatisfaction or frustration with work or the work environment.
SecurityAwareness	low, medium, high	Employee knowledge and awareness of security risks and safe behaviour.
PolicyCompliance	good, poor	Extent to which employees and processes adhere to security policy.
ConcerningBehaviour	no, yes	Observed behaviour suggesting possible malicious intent or misuse.
PrivilegedAccess	appropriate, excessive	Whether access rights are appropriate for the role or excessively granted.
TechnicalControls	weak, adequate	Strength of preventive and detective technical measures (logging, Data Loss Prevention, etc.).
MonitoringAlert	no, yes	Whether monitoring generated an alert from behavioural or technical signals.
InsiderThreatIncident	no, yes	Whether a malicious insider-related security incident occurred.

1 Introduction

When a security team suspects an insider threat, HR may report low morale, IAM tools may flag excessive privileged access, and monitoring may raise alerts—yet it remains unclear how likely a real incident is. Shareable insider-incident data are scarce [1], so models must combine expert judgement with partial observations rather than rely on large labelled breach corpora. Bayesian Networks (BNs) encode such judgement as a directed graph. They update $P(I=\text{yes} \mid E)$ as evidence arrives, exposing *which* factors raise risk rather than a single opaque score. A flat classifier could rank cases. It would not, however, separate expert causal structure from fitted parameters or support transparent what-if queries when evidence changes. Chockalingam et al. [1] find that published cyber-security BNs are typically small and expert-parameterised. Most follow a People–Process–Technology structure, focus on malicious insiders, and rarely integrate insider–outsider models. Earlier insider-threat BNs link dissatisfaction, behaviour, and access misuse to higher risk [2]. Against that background we build and test a compact eight-node network (Tables 1–2). Our goal is to assess whether such an expert-built model can help analysts prioritise cases when signals are only partly visible and shareable incident data are scarce. We hypothesise that a domain-informed causal network yields interpretable risk estimates and remains competitive with data-driven alternatives on synthetically generated cases. We therefore examine scenario inference from expert probabilities, structure recovery as training data grow, incident prediction against learned and simpler classifiers on a small unseen set, and whether a parsimonious incident parameterisation preserves rising risk when more warning signs are active.

2 Methods

2.1 Setup

Four steps: (1) specify the DAG and CPTs by expert judgement and test by inference only; (2) generate $N=2000$ synthetic cases from that BN because real insider logs are unavailable; (3) run structure learning and classification on held-out subsets; (4) compare noisy-OR with a fuller incident CPT. For classification we draw Train/Test = 100/100 cases from a 300-row pool, **stratified** on I . Learning experiments are deliberately circular—they measure recoverability of a known graph, not external validity.

2.2 Network

Roots capture dissatisfaction and security awareness; process compliance shapes access; people and technology indicators feed the incident node. Causally, dissatisfaction may precede concerning behaviour; weak controls influence both incidents and alerts. The incident CPT is a noisy-OR over three activators: concerning behaviour (yes), excessive privileged access, and weak technical controls. Figure 1 summarises the structure.

Causal DAG — insider-threat risk (People–Process–Technology)

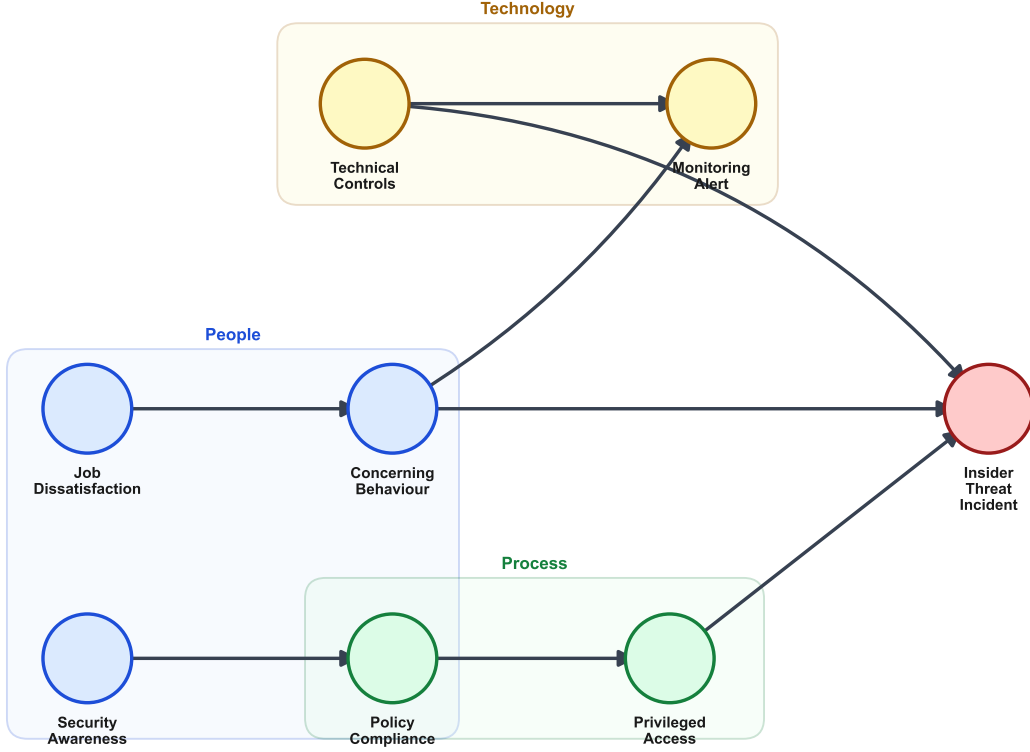


Figure 1: Causal DAG for insider-threat risk.

2.3 Learning

For each $n \in \{100, 500, 1000\}$, learn structure and compare to the manual DAG (skeleton/directed F_1 , Hamming distance). For classification, we fix Train/Test = 100/100 (stratified on I): *original* BN (expert DAG, CPTs on Train), *learned* BN (Hill Climbing on Train), and *naive Bayes* on the same variables. Primary metric: AUC. CPT fitting uses smoothing when 100 training rows leave parent configurations unobserved. Each experiment is repeated over 30 independent resamples (mean and 95% percentile intervals). We compare four noisy-OR parameters with seven in a fuller logistic CPT, inspect $P(I=\text{yes})$ as activators turn on, and contrast Hill Climbing with MIIC for structure recovery. Domain-specific choices include a People–Process–Technology DAG, a noisy-OR incident node, and scenario evidence on the alert pathway.

2.4 Data management

All learning cases are simulated from the ground-truth BN ($N=2000$); no identifiable employee records were collected.

3 Results

3.1 Inference validation

With the expert DAG and CPTs fixed, inference propagates evidence only. Table 3 and Figure 2 list five evidence profiles: high risk more than doubles baseline $P(I=\text{yes})$ (0.74 vs. 0.33); low risk falls to 0.06; an alert without a full pathway stays below baseline (0.19), consistent with the DAG. Dissatisfaction alone raises risk moderately (0.40). Varying the noisy-OR leak ($q \in \{0.90, 0.94, 0.97\}$) preserves the ordering high-risk > baseline > low-risk.

Scenario	Key evidence set	$P(I=\text{yes})$
Baseline	(none)	0.334
High risk	CB=yes, PA=excessive, TC=weak	0.743
Low risk	CB=no, PA=appropriate, TC=adequate	0.060
Alert, low incident	MA=yes, CB=no, TC=adequate	0.192
High dissatisfaction	JD=high	0.403

Table 3: Scenario inference. CB = concerning behaviour; PA = privileged access; TC = technical controls; MA = monitoring alert; JD = job dissatisfaction.

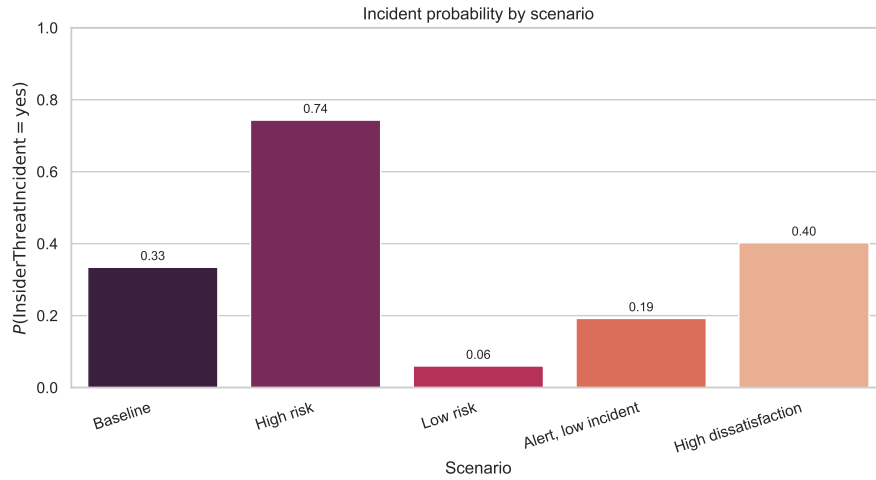


Figure 2: Incident probability by scenario.

3.2 Structure recovery

Figure 3 and Tables 4–5 summarise learning from random subsets. Table 4 gives one reference run (seed 42); Table 5 aggregates 30 resamples. Mean skeleton F_1 rises with n ; directed recovery stays harder for Hill Climbing, whereas MIIC reaches mean directed $F_1 \approx 0.96$ at $n=1000$.

n	Algo.	Skeleton F_1	Directed F_1	Hamming
100	HC	0.857	0.571	2
100	MIIC	0.857	0.286	2
500	HC	0.941	0.588	1
500	MIIC	1.000	1.000	0
1000	HC	0.889	0.111	2
1000	MIIC	1.000	1.000	0

Table 4: Reference structure-learning metrics (seed 42).

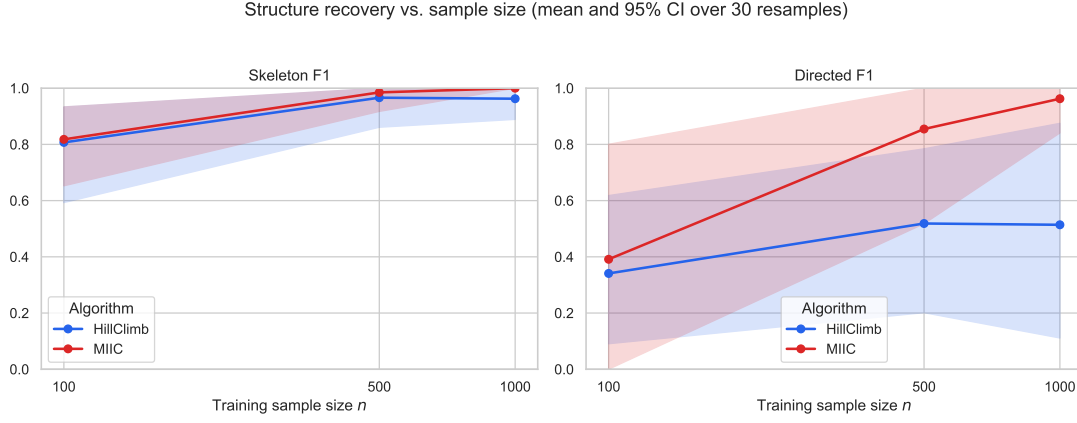


Figure 3: Structure recovery vs. n (mean and 95% CI over 30 resamples).

n	Algo.	Skeleton F_1 [95% CI]	Directed F_1 [95% CI]
100	HC	0.807 [0.593, 0.933]	0.341 [0.091, 0.618]
100	MIIC	0.818 [0.653, 0.933]	0.391 [0.000, 0.800]
500	HC	0.966 [0.861, 1.000]	0.519 [0.201, 0.784]
500	MIIC	0.985 [0.917, 1.000]	0.855 [0.518, 1.000]
1000	HC	0.963 [0.889, 1.000]	0.514 [0.111, 0.875]
1000	MIIC	1.000 [1.000, 1.000]	0.963 [0.841, 1.000]

Table 5: Structure recovery stability (mean and 95% CI over 30 resamples).

Mean skeleton F_1 rises with n for both algorithms. Directed recovery stays harder for Hill Climbing; MIIC reaches mean directed $F_1 \approx 0.96$ at $n=1000$, so constraint-based search appears better suited to orientation when the ground truth is known.

3.3 Classification

Reference and stability results appear in Tables 6–7 and Figures 4–5. On one split, AUC ranges from 0.700 to 0.717; over 30 resamples the 95% intervals overlap and no classifier clearly dominates.

Model	AUC	Accuracy
Original BN	0.713	0.64
Learned BN (HC)	0.700	0.64
Naive Bayes	0.717	0.65

Table 6: Reference test performance on held-out cases.

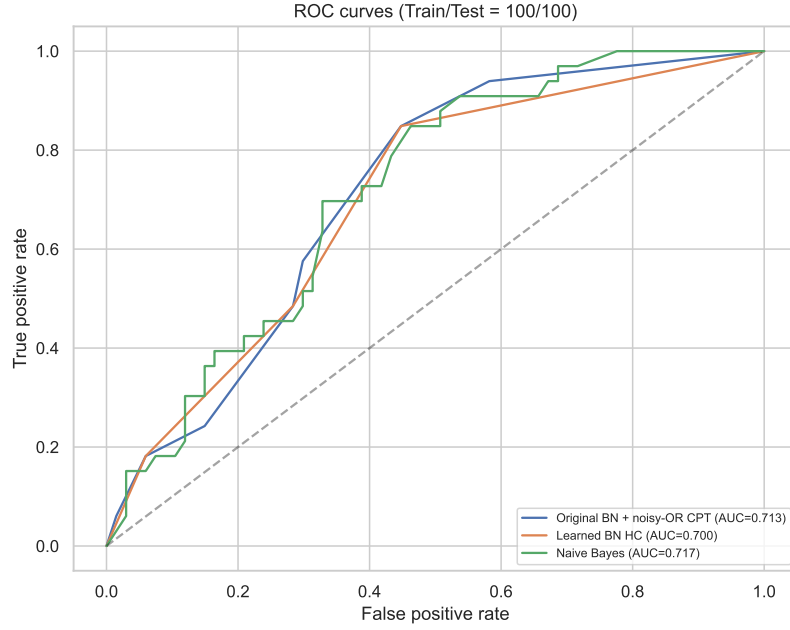


Figure 4: ROC curves on the reference split.

Model	AUC [95% CI]	Accuracy [95% CI]
Original BN	0.764 [0.692, 0.844]	0.700 [0.629, 0.770]
Learned BN (HC)	0.736 [0.582, 0.844]	0.721 [0.635, 0.796]
Naive Bayes	0.757 [0.664, 0.832]	0.722 [0.645, 0.783]

Table 7: Classification stability over 30 resamples.

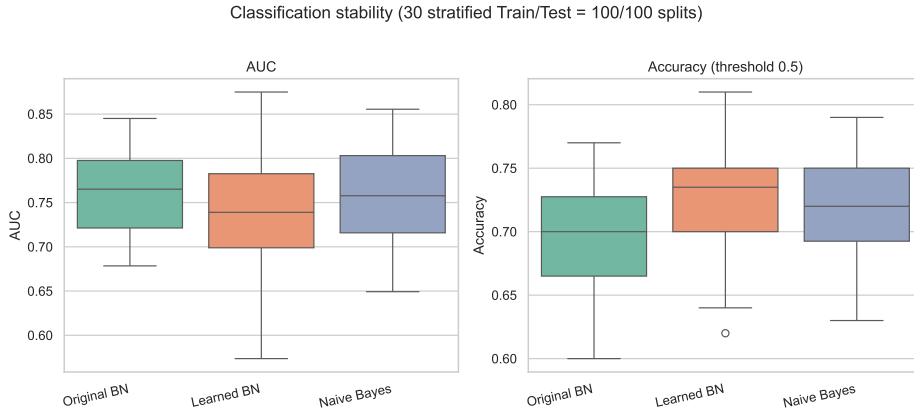


Figure 5: Distribution of AUC and accuracy over 30 resamples.

3.4 Noisy-OR evaluation

Noisy-OR uses four parameters instead of seven while preserving monotonic multi-cause risk (Figure 6).

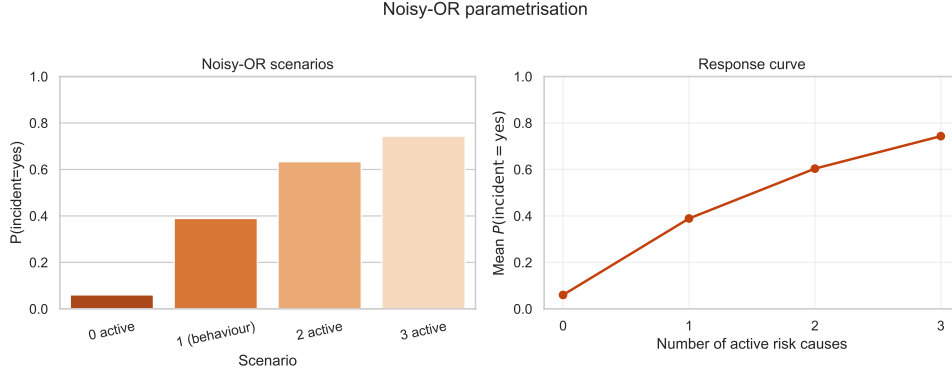


Figure 6: Noisy-OR scenarios and response curve.

4 Conclusions and discussion

4.1 Summary of findings

This study asked whether a compact, expert-built Bayesian Network can support insider-threat prioritisation when real incident data are scarce. The results suggest a qualified yes.

Scenario inference on the hand-specified model produced stable, interpretable risk estimates. High- and low-risk profiles separated clearly; intermediate cases, such as an alert without a full incident pathway, behaved in line with the DAG. That pattern supports transparent what-if reasoning rather than a single opaque score.

On synthetic data generated from the same BN, structure recovery improved with sample size for both algorithms. Skeleton connectivity was recovered more reliably than edge direction. Hill Climbing showed wide directed- F_1 intervals at all training sizes; MIIC reached mean directed $F_1 \approx 0.95$ at $n=1000$. Constraint-based search therefore appears better suited to orientation when the ground truth is known.

Classification on repeated stratified 100/100 splits yielded overlapping 95% AUC intervals across the original BN, a learned BN, and naive Bayes. No classifier clearly dominated; a single reference split can rank models differently from the stability analysis.

Noisy-OR reduced the incident node from seven to four free parameters while preserving monotonic multi-cause risk—a useful trade-off for interpretability and elicitation effort in a small expert model.

4.2 Limitations

The evaluation is deliberately inward-looking. Learning data are simulated from the same BN that defines the ground truth, so structure and classification metrics measure recoverability rather than external validity. CPTs reflect expert judgement and are not calibrated on operational insider-incident records. The scope is limited to malicious insiders in a static People–Process–Technology graph, consistent with many published models but narrower than combined insider–outsider threats [1]; temporal evolution of HR signals and alert streams (e.g. via dynamic BNs) is not modelled. Train and test sets are small ($n=100$ each), which widens confidence intervals: overlapping 95% AUC bands (e.g. original BN 0.764 vs. naive Bayes 0.757) do not support a definitive ranking of classifiers.

4.3 Implications and future work

Expert causal structure still earns its place under data scarcity: it explains *why* a score rises when concerning behaviour and weak controls coincide, and it remains competitive on average with learned alternatives. The pipeline should be read as a proof of concept, not as validation on live security-operations data or as an autonomous detection system. Any deployment would require mandatory human review, auditability of evidence, and clear separation between prioritisation support and disciplinary action.

A realistic next step is to map operational feeds—identity management, policy compliance, Data Loss Prevention and SIEM alerts—to the eight nodes and to preregister the elicitation and evaluation protocol before touching production data. CPT workshops should be documented with sensitivity analysis on key parameters such as the noisy-OR leak. Field trials could compare analyst prioritisation with and without BN scores, measuring time-to-triage and false-priority rates rather than accuracy alone.

Data and code availability

All analysis code, the reproducible Jupyter notebook, exported report figures, and supplementary materials are publicly available at github.com/jruijgrok141/insider-threat-bayesian-network (MIT license). Numeric tables in §3 match `report/figures/*.csv`, generated by `report/export_figures.py` (structure stability uses 30 resamples there; the notebook reproduces classification stability and single-run structure learning). Structure-learning and classification experiments use synthetically generated cases drawn from the expert-specified Bayesian network described in this report; no identifiable employee or operational security records were used.

References

- [1] S. Chockalingam, W. Pieters, A. Herdeiro Teixeira, and P. van Gelder (2017). Bayesian network models in cyber security: A systematic review. In *Proc. NordSec 2017* (LNCS 10674, pp. 105–122). Springer. https://doi.org/10.1007/978-3-319-70290-2_7
- [2] E. T. Axelrad, P. J. Sticha, O. Brdiczka, and J. Shen (2013). A Bayesian network model for predicting insider threats. In *IEEE Security and Privacy Workshops*, pp. 82–89.